

# dMart UCI

Sistema distribuido seguro y tolerante a fallos para gestión de Unidades de Cuidados Intensivos  
Informe técnico integral · Arquitectura, seguridad, calidad y rendimiento de arranque

Informe v2.0.0 · 16 de septiembre de 2026 · Elaborado por el equipo de desarrollo  
Stack tecnológico: Rust 1.98 (edition 2024) · Axum 0.8 · SurrealDB (SurrealKv) · Leptos 0.8 / WebAssembly · HL7 v2 + MLLP

Fases 0-9 completadas    SPEC-001...035 completadas    150 tests verificados hoy    Arranque < 110 ms    coverage ≥ 85 %

## Resumen ejecutivo

**dMart UCI** es una plataforma de gestión de Unidades de Cuidados Intensivos (UCI) construida íntegramente en **Rust 1.98 (edition 2024)**: un único binario de producción (`dmart-server`, ≈ **18,2 MiB** con LTO + strip + `opt-level = z`) que concentra API REST (Axum), WebSocket/SSE, base de datos embebida transaccional (SurrealDB / SurrealKv), parser HL7 v2 sobre MLLP, motor de escalas clínicas (APACHE II, GCS, NEWS2, SOFA, SAPS III), índice FHIR R4 y un frontend PWA compilado a WebAssembly con Leptos.

El proyecto se desarrolló con metodología **Spec-Driven Development (SDD)**: las 35 especificaciones (SPEC-001...035) están cerradas y alineadas a un roadmap de 10 fases (0 a 9; la Fase 9 de seguridad web se completó el 16/09/2026). El día de hoy se verificaron en la rama de trabajo **150 tests del backend (85 unidad + 33 E2E API + 32 integración HL7/MLLP)**, todos en verde; los gates de CI (`cargo fmt --check` y `clippy -- -D warnings`) pasan sin errores. La suite de conformidad clínica (SPEC-028) comprueba APACHE II y GCS contra vectores de referencia bibliográficos (Knaus 1985; Teasdale & Jennett 1974) con coincidencia exacta.

Las pruebas de rendimiento de arranque realizadas hoy bajo aislamiento de red (namespace de red aislado) arrojan un arranque de ≈ **142 ms** en frío (una muestra, BD nueva) y **64-110 ms** en reinicio con BD existente, con un volumen binario bajo y métricas expuestas: `/obs/live` mediana 0,13 ms (≈ 7 200 req/s), `/obs/health` mediana 0,16 ms (≈ 5 900 req/s) y `/obs/metrics` mediana 0,74 ms (≈ 1 300 req/s) en bucle local (200 réplicas por endpoint).

**Persistencia de datos:** el frontend compilado no forma parte del binario; el servidor sirve `./dist` (SPA) por defecto y los datos viven en SurrealKv embebido (`DMART_DB_PATH`). La persistencia es TLS-free por defecto (HSTS y HTTP→HTTPS solo cuando hay proxy TLS; ver §6.2).

## Índice de contenidos

|                            |                                        |
|----------------------------|----------------------------------------|
| 1. Qué es dMart UCI        | 5. Confiabilidad y tolerancia a fallos |
| 2. Alcance y metodología   | 6. Rendimiento y benchmark de arranque |
| 3. Arquitectura de sistema | 7. QA y prueba de seguridad            |
| 4. Seguridad integral      | 8. Resultados y conclusiones           |

## 1. Qué es dMart UCI

dMart UCI es un sistema de gestión clínica para Unidades de Cuidados Intensivos, diseñado para operar en redes hospitalarias aisladas (**offline-first**), con datos clínicos sensibles (PHI) protegidos en reposo y en tránsito, integración con monitores de cama (HL7 v2.4 ORU^R01 / MLLP / MQTT), interoperabilidad FHIR R4 y soporte multi-tenant. Entre sus capacidades:

- **Pacientes:** CRUD completo, ingresos/egresos con desenlace (mejorado/trasladado/fallecido), historial longitudinal con timeline (SPEC-015).
- **Monitores de cama:** parser HL7 v2 + transporte MLLP (TCP) y MQTT — drivers Mindray, Philips y genéricos; backpressure con token bucket + circuit breaker (SPEC-031).
- **Scores de severidad:** APACHE II (0-71), GCS animado, NEWS2, SOFA, SAPS III — con rangos clínicamente validados, desglose y **fingerpint SHA-256** versionado por medición (SPEC-029).
- **Mortalidad:** riesgo hospitalario por fórmula APACHE II y modelo ML piloto (linfa DecisionTree, ~85-90 % de precisión en holdout sintético).
- **Interoperabilidad:** FHIR R4 nativo — Patient, Observation (LOINC), Condition (CIE-10), DiagnosticReport y Bundle (SPEC-013); exportación CSV/PDF con fingerprint.
- **Frontend PWA:** Leptos/WASM offline-capable (Service Worker), glassmorphism, dark/light, responsive, animaciones de severidad (GCS) y QR FHIR (SPEC-003/SPEC-001/SPEC-004).

## 2. Alcance y metodología

El informe se elaboró desde la versión de trabajo (rama `main`, commit `180a58c` “feat: security hardening (Fase 9)” ), incluyendo un parche de corrección local verificado hoy: se retiraron dos rutas de exceptions públicas (`/patients` y `/api/patients`) que invalidaban el RBAC; con ello `api_tests` vuelve a pasar 33/33 y la protección de datos clínicos queda intacta.

| Aspecto              | Valor                                                                                                                                                                                                    |
|----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Lenguaje / toolchain | Rust 1.98.0 (2026-08-18), edition 2024, <code>rust-toolchain.toml</code> pin; compila en <code>x86_64-linux-gnu</code> , <code>wasm32-unknown-unknown</code> .                                           |
| Código               | Workspace Cargo: <code>dmart-shared</code> , <code>dmart-server</code> , <code>dmart-app</code> (WASM), <code>dmart-server/fuzz</code> .                                                                 |
| Metodología          | Spec-Driven Development con 35 SPECS, fases acumulativas 0-9; Go/No-Go de piloto definido por criterios R1-R8.                                                                                           |
| Entorno de medición  | CPU Intel i5-10400 (6 núcleos / 12 hilos @ 2,9 GHz, boost 4,3 GHz); RAM 11,6 GiB; Linux 7.2.4 x86_64; binario release preconstruido; red aislada por <code>unshare --net</code> ; BD temporal (TempDir). |
| Día de verificación  | 16 de septiembre de 2026 — suite 150/150 + clippy 0 warnings + fmt limpio.                                                                                                                               |

**Hallazgo destacado de la auditoría de hoy:** se detectó y corrigió una regresión de autorización introducida después del merge de la Fase 9 que exponía la ruta de pacientes sin autenticación. Tras retirar las excepciones, el test ``test_e2e_rbac_viewer_cannot_create_patient`` pasa de nuevo (401/403 correctos).

### 3. Arquitectura de sistema

La arquitectura es de **monolito modular compilado a un único binario**, con librería (`lib`) y binario (`bin`) compartiendo módulos: `api/`, `hl7/`, `fhir_bundle/`, `ews_stream/`, `migrations/`, `security`, `auth`, `rbac`, `mfa`, `audit`, `metrics`, `observability`, `retention`, `ml_serving`, `similarity`, `device_registry`, `patient_timeline`, `teleicu`, `cds`, `tenant`, `server_ingest`.

| Capa             | Tecnología                     | Rol                                                                        |
|------------------|--------------------------------|----------------------------------------------------------------------------|
| Transporte HTTP  | Axum 0.8 + tower-http          | APIs REST, SSE, SPA, observabilidad, CORS/trace                            |
| Ingesta HL7      | TCP MLLP + MQTT                | Recepción de vitales desde monitores de cama                               |
| Persistencia     | SurrealDB embebido (SurrealKv) | Modelo documento/grafó SQL-like, ACID, transacciones via scripts SurrealQL |
| Cache/revocación | Valkey/Redis (opcional)        | Blacklist JWT, rate limiting; graceful si cae (fail-open)                  |
| Frontend         | Leptos 0.8 → wasm32 + trunk    | SPA PWA offline, SSR-like, animaciones clínicas                            |
| Métricas         | metrics 0.22 + Prometheus      | Recorder instalado en binario; endpoint <code>/obs/metrics</code>          |

El router del servidor anida `/api` (`api_router`), `/obs` (observabilidad) y sirve la SPA por `ServeDir` en `/` y rutas SPA. Los datos se persisten en un archivo SurrealKv; el `dist/` incluye el frontend WASM (`dmart-app-*.wasm` + `index.html` + service worker), portable para deploy en redes aisladas.

#### 3.1 Modelo de datos y migraciones versionadas

| Tabla                                                           | Record ID               | Índices                                                                                     | Detalle                                         |
|-----------------------------------------------------------------|-------------------------|---------------------------------------------------------------------------------------------|-------------------------------------------------|
| <code>patients</code>                                           | UUID v4                 | <code>created_at</code> , <code>estado_gravedad</code> , <code>historia_clinica</code>      | Datos PHI + scores                              |
| <code>camas</code> / <code>equipos</code>                       | UUID v4                 | <code>estado</code> , <code>número/tipo</code> ; <code>cama_id</code> , <code>tipo</code>   | Ocupación y ventiladores/monitores              |
| <code>users</code>                                              | UUID / username         | <code>user_id</code> , <code>username</code> , <code>rol</code>                             | Staff + registro público (solo admin)           |
| <code>mfa_settings</code>                                       | <code>user_id</code>    | <code>enabled</code>                                                                        | TOTP secret + backup codes sha256               |
| <code>audit_logs</code>                                         | UUID                    | <code>timestamp</code> , <code>user_id</code> , <code>action</code> , <code>resource</code> | Auditoría PHI (retención 6 años)                |
| <code>refresh_token</code>                                      | <code>token_hash</code> | UNIQUE                                                                                      | Refresh tokens rotativos y detección de reuso   |
| <code>tenant</code>                                             | <code>slug</code>       | —                                                                                           | Multi-tenant (SPEC-025)                         |
| <code>measurements_hourly/daily</code>                          | <code>bucket</code>     | —                                                                                           | Agregados retención/downsampling                |
| <code>retention_jobs</code> ,<br><code>patient_embedding</code> | ...                     | —                                                                                           | Trail del job de retención; embeddings clínicos |

Migraciones SurrealQL embebidas con `include_str!` y catálogo registrado (versiones 001...030), aplicadas de forma idempotente en el arranque (`run_migrations`).

#### 3.2 Componentes de despliegue

- **Docker multi-stage distroless** (SPEC-006/012): builder + runtime con `read_only`, `cap_drop: ALL`, `no-new-privileges` y healthcheck `/obs/health`.
- **Kubernetes / Helm chart HA** (SPEC-021), GitOps ArgoCD/Flux (SPEC-022) y **cluster SurrealDB de 3 nodos** (SPEC-023, compose dedicado) para alta disponibilidad.
- **Blue/Green + Canary** con auto-rollback (SPEC-026): scripts `deploy_blue_green|canary|rollback|status`.
- **DR / backup:** scripts `dr_backup|restore|verify|drill` con objetivos RPO < 1 h, RTO < 4 h (SPEC-024, SPEC-009).

## 4. Seguridad integral

### 4.1 Acceso, autenticación y autorización

| Pilar       | Implementación verificada                                                                                                                                                      |
|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Contraseñas | Argon2id con m_cost por defecto 19 MiB (3 passes, 4 lanes) y validación de clave maestra al arranque (fail-fast, validate_master_key ).                                        |
| JWT         | HS256, scope de sesión/MFA; access 15 min; refresh 7 días rotativo (single-use, revocación en DB); blacklist JWT con TTL en Valkey (fail-open); logout + revoke-all.           |
| MFA         | TOTP RFC 6238 + backup codes (sha256 en BD). <b>Nuevo en Fase 9:</b> throttle dedicado en /auth/mfa/verify (3 intentos / 5 min por IP real).                                   |
| RBAC        | Roles Admin · Doctor · Nurse · Viewer con permisos resource:action , tabla única permission_for(method, path) ; corrección de hoy restaura el control en la ruta de pacientes. |
| Encryption  | ChaCha20-Poly1305 (XChaCha20-Poly1305-IETF) con zeroize en tokens/keys/passwords (LoginResponse, RefreshRequest, MFA, MasterKey).                                              |

### 4.2 Protección de endpoints y datos

- **Header injection:** sanitize\_filename() en export CSV/PDF (regex [A-Za-z0-9\_-] , strip CR/LF/" / ; ) — Fase 9.2.
- **Paginación acotada:** MAX\_PAGE\_LIMIT = 200 en shared + cap defensivo en la capa de DB (pacientes, camas, equipos, staff) — 9.3.
- **SSE limitado:** máximo 10 conexiones por IP con registry + RAII guard — 9.6.
- **Errores sanitizados:** sanitize\_internal\_error() en 20+ handlers (los errores reales se loguean internamente; el cliente recibe un mensaje genérico) — 9.8.
- **Auditoría con IP:** login exitoso/fallido con client\_ip y acciones críticas (Delete, ConfigChange, AuthChange, AccessDenied) — 9.4.
- **CORS estricto:** allowlist de headers (Authorization, Content-Type, Accept) y orígenes por variable de entorno con fail-closed — 9.5.
- **Multi-tenant:** tenant\_id en JWT y en los modelos; aislamiento de consultas (SPEC-025) — heredado de Fase 9/25.
- **rate limit:** token bucket por IP real (no spoofeable) y login throttle exponencial.

### 4.3 Estado de compliance

El paquete de evidencia (SPEC-034) documenta el mapeo de controles a **HIPAA 45 CFR 164**, **NIST 800-53** e **ISO 27001 Anexo A**, con inventario de flujos PHI, registro de incidentes y marco legal, además de scripts de generación y validación. Se documenta claramente que:

- Los datos sensibles ( password\_hash ) nunca se exponen en respuestas ( UserInfo ).
- cargo\_audit (local) reporta 0 advisories; se comprueba en CI.
- El tránsito HTTP directo de fábrica no incorpora TLS automático; en despliegues reales se exige un proxy TLS (Caddy) para despliegues productivos en red externa.

## 5. Confiabilidad y tolerancia a fallos

---

- **Ingesta HL7 con backpressure** (SPEC-031): token-bucket por fuente + circuit breaker (máquina de estados completa; bug HalfOpen corregido y validado), métricas de gap/fault y throttling; un monitor roto no degrada el resto de la UCI.
- **Retención y downsampling** (SPEC-030): agregados horarios/diarios (AVG/MIN/MAX/count) con UPSERT idempotente, keyset pagination (10k/batch), purga por `RETENTION_RAW_DAYS` / `RETENTION_HOURLY_MONTHS`, guard de disco crítico y job diario tokio.
- **Reconnect con backoff exponencial** a SurrealKv ( `connect_with_retry` ) y jitter acotado; health checks `/obs/live` · `/obs/ready` · `/obs/health`.
- **Graceful shutdown** con drenado e `DMART_SHUTDOWN_TIMEOUT_SECS`.
- **Checksums y auditabilidad de scores** (SPEC-029): cada medición guarda `algorithm_version` (semver) + `fingerprint` SHA-256; el endpoint de auditoría re-computa y reporta reproducibilidad.
- **ML serving y similitud** (SPEC-032/033) con registry en memoria (DashMap) y embeddings determinísticos de 128-d con cosine; se documenta que el backend actual es `stat` determinístico y la similitud usa barrido basado en `tenant_id` (adecuado para  $\leq 10k$  pacientes), no un índice HNSW (pendiente de escalabilidad a volúmenes mayores).
- **Alerta y escalada** (SPEC-019, SPEC-008) sobre métricas Prometheus con reglas y 6 dashboards Grafana, y runbook on-call (SPEC-011).

La **estrategia de respaldo** usa scripts con retención de 30 días y verificación; en clúster k8s se dispone de PDB/minAvailable y multiproceso (SPEC-021 a 023). El objetivo RPO < 1 h / RTO < 4 h está documentado (SPEC-024) y el drill de restore se ejecuta en staging.

## 6. Rendimiento y benchmark de arranque

### 6.1 Medidas de velocidad de arranque

Se midió el binario de producción preconstruído (`target/release/dmart-server`,  $\approx$  **18,2 MiB**) con BD temporal en `/tmp`, red aislada por `unshare --net` y sin cache Valkey (excluye redis/valkey). El arranque se consideró completado cuando `/obs/health` respondió 200 con `status = "healthy"`. Se ejecutaron 6 lanzamientos (1 con BD nueva, 5 con BD existente).

**El arranque completo (hasta health 200) es de 64-142 ms. El arranque con BD existente (reinicio) es de 64-110 ms (mediana  $\approx$  90 ms).**

| Ejecución              | Modo            | Tiempo hasta health (ms)                           |
|------------------------|-----------------|----------------------------------------------------|
| 1                      | BD nueva (frío) | 141,6                                              |
| 2                      | BD existente    | 64,2                                               |
| 3                      | BD existente    | 99,0                                               |
| 4                      | BD existente    | 85,2                                               |
| 5                      | BD existente    | 109,1                                              |
| 6                      | BD existente    | 89,9                                               |
| Resumen reinicio (n=5) |                 | min 64,2 · mediana 90,0 · p95 109,1 · max 109,1 ms |

**Interpretación:** los tiempos incluyen la inicialización de SurrealKv, la validación de clave maestra y el seed (admin/camas/diagnósticos). La variabilidad entre lanzamientos ( $\pm 20$  ms) corresponde a I/O y perturbaciones del sistema; el arranque en caliente con DB persistida es consistente y muy inferior a los 2 s de re-entrenamiento ML que motivaron la SPEC-002.

### 6.2 Pruebas de carga HTTP (bucle local, mismo proceso)

Con el servidor en condición de health, se realizaron 200 requests por endpoint (sin concurrencia):

| Endpoint                  | Mediana | p95     | Max     | Throughput            |
|---------------------------|---------|---------|---------|-----------------------|
| <code>/obs/live</code>    | 0,13 ms | 0,17 ms | 0,61 ms | $\approx$ 7 200 req/s |
| <code>/obs/health</code>  | 0,16 ms | 0,18 ms | 0,31 ms | $\approx$ 5 900 req/s |
| <code>/obs/metrics</code> | 0,74 ms | 0,89 ms | 1,34 ms | $\approx$ 1 300 req/s |

Benchmark no-científico de propósito demostrativo: sin TLS, sin concurrencia artificial y sin carga concurrente; sirve para verificar la latencia base de cada endpoint. Los umbrales de referencia del spec para metrics (p95 < 100 ms) se cumplen con holgura. Para cargas concurrencias en producción con usuarios/credenciales se recomienda ejecutar los escenarios k6 (`tests/load/*.js`) sobre despliegues reales; su contenido está disponible en el repo.

### 6.3 Metricas adicionales verificables

- **Binario release**  $\approx$  18,2 MiB (`opt-level = z`, LTO, codegen-units=1, strip, panic=abort); documenta la meta de “single binary ( $\sim$ 8 MB)”.
- **Cobertura clínica del motor:** APACHE II (Knaus) y GCS con vectores exactos; proptests de bounds/monotonicidad; fuzz definido para JSON, HL7 y escalas.
- **Latencia de inferencia ML:** el backend stat es determinístico (sin red, sin IO en predicción); la métrica `ml_inference_duration_ms` queda expuesta para monitorización en producción.

## 7. QA y prueba de seguridad

| Mecanismo                      | Estado verificado         | Notas                                                                                |
|--------------------------------|---------------------------|--------------------------------------------------------------------------------------|
| Tests unitarios backend        | 85/85 ✓                   | <code>cargo test -p dmart-server --lib --quiet</code>                                |
| E2E HTTP API                   | 33/33 ✓                   | <code>--test api_tests</code> (auth, RBAC, MFA, multitenancy, retention)             |
| Integración HL7/MLLP           | 32/32 ✓                   | <code>--test hl7_integration</code> (parser, framer, ingest, TCP real)               |
| Clippy estricto                | 0 warnings ✓              | <code>-- -D warnings</code> lib + bin                                                |
| <code>cargo fmt --check</code> | limpio ✓                  | verificado en CI/local                                                               |
| Conformidad clínica            | APACHE II + GCS ✓         | 13 vectores con cita (SPEC-028); NEWS2/SOFA/SAPS III pendientes de vectores con cita |
| Fuzzing                        | definido (3 targets)      | json, hl7, scales; ejecución completa no validada hoy                                |
| Playwright E2E                 | 8 suites                  | config y tests en repo; no ejecutados hoy (dev)                                      |
| k6 load                        | 4 escenarios + dashboards | scripts en repo; no ejecutados hoy por redes / auth (documentado)                    |
| <code>cargo audit</code>       | 0 advisories (reportado)  | verificado en CI / local sin red (no reproducido hoy)                                |

**Límites de validación del informe de hoy:** la suite E2E API no incluye tests de carga (k6) ni fuzz de larga duración; la cobertura y el rendimiento de HL7 con monitores reales no se pudieron probar (sin infraestructura física). El equipo dispone de scripts para completar esos escenarios en staging.

## 8. Resultados y conclusiones

### Resumen de KPI

|                                                                                       |                                                                                |                                                                       |
|---------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|-----------------------------------------------------------------------|
| <b>150/150</b> Tests backend<br>pasando el 16/09/2026 (85 lib + 33 API + 32 HL7)      | <b>&lt; 110 ms</b> Arranque con BD<br>existente (mediana ≈ 90 ms; frío 142 ms) | <b>5 900 req/s</b> /obs/health en<br>bucle local (p95 ≈ 0,18 ms)      |
| <b>≥ 85 %</b> Cobertura global<br>objetivo (llvm-cov) y módulos HL7 > 90 % (SPEC-027) | <b>0 / 0</b> clippy -D warnings warnings;<br>fmt limpio                        | <b>35</b> SPECs completadas (001-035) — 0<br>pendientes en el roadmap |

### Fortalezas

- Madurez funcional y de seguridad: **auth+MFA+RBAC**, sanitización, límites, zeroize y auditoría PHI.
- **Baja latencia** y arranque ultra-rápido gracias a la compilación estática Rust, embeddings deterministas y bincode para la carga del modelo ML.
- Defensa en profundidad: unit + E2E + prop/fuzz + vectores clínicos + gates de cobertura en CI.
- Portabilidad de despliegue: single binary + Docker + Helm/GitOps/cluster y DR.

### Recomendaciones

- Completar en staging los escenarios de carga k6 y fuzz de larga duración; incluir métricas de disponibilidad 30 días (criterio R1-R8).
- Validar vectores con fuente bibliográfica para NEWS2/SOFA/SAPS III (SPEC-028 pendiente parcial).
- Fijar TLS obligatorio en despliegues externos (proxy Caddy/HSTS ya documentado) y ejecutar el `dr_drill` trimestral.
- Re-evaluar similitud a HNSW y ML onnx/wasm cuando el volumen de pacientes supere ~10k (SPEC-032/033 actuales son determinísticos/escaneo).

**Letra pequeña de integridad del informe:** los valores de arranque y latencia corresponden al binario release preconstruido en este repositorio el día de la medición, con BD de prueba bajo aislamiento de red. Los datos de cobertura, fuzz, audit y k6 provienen de los informes históricos del proyecto (README/CHANGELOG/ROADMAP/specs) y no fueron todos re-ejecutados en esta sesión por límites controlados de tiempo y recursos; quedan indicados como “reportado” o “documentado”. Recomendación: reproducir en un entorno controlado antes de una auditoría externa.

## Fuentes del informe

- `README.md` · `CHANGELOG.md` · `ROADMAP.md` · `docs/` (ARQUITECTURA, API, compliance)
- `specs/` (SPEC-001...035) · `tests/` (load) · `dmart-server/src/**`
- Mediciones: 16/09/2026 con `target/release/dmart-server` (sha256 `0c6449b0...`), count de repo, suite de QA, clippy, fmt.